

**IMPLEMENTASI MEKANISME *LEAST PRIVILEGE*
DAN *JUST-IN-TIME ACCESS* PADA LAYER KONTROL
AKSES PENGGUNA INTERNAL DALAM PROTOTIPE
SISTEM DOMPET DIGITAL**

PROPOSAL TUGAS AKHIR

Diajukan Oleh :

MUHAMMAD SYUKUR

220705058

**Mahasiswa Fakultas Sains dan Teknologi
Program Studi Teknologi Informasi**



**FAKULTAS SAINS DAN TEKNOLOGI
UNIVERSITAS ISLAM NEGERI AR-RANIRY
BANDA ACEH
2026 M/1447 H**

DAFTAR ISI

DAFTAR ISI	ii
DAFTAR GAMBAR	iv
DAFTAR TABEL	v
BAB I PENDAHULUAN	1
1.1 Latar Belakang	1
1.2 Rumusan masalah.....	4
1.3 Tujuan Penelitian.....	4
1.4 Manfaat Penelitian.....	5
1.5 Batasan Penelitian	6
BAB II TINJAUAN PUSTAKA	7
2.1 Penelitian Terkait.....	7
2.2 Sistem Dompot Digital	10
2.3 Kontrol Akses	11
2.4 <i>Role-Based Access Control</i> (RBAC)	12
2.5 <i>Least Privilege</i>	14
2.6 <i>Just-In-Time Access</i>	15
2.7 Relevansi pada Sistem Dompot digital	17
BAB III METODE PENELITIAN	19
3.1 Pendekatan Penelitian.....	19
3.2 Alur Penelitian.	19
3.3 Analisis Sistem dan Kebutuhan Kontrol Akses	21
3.3.1 Identifikasi Pengguna Internal.....	21
3.3.2 Pemetaan Fitur Sistem dan Penerapan <i>Least Privilege</i>	22
3.3.3 Identifikasi Fitur Sensitif dan Logika <i>Just-In-Time Access</i>	25
3.3.4 Mekanisme dan Logika Persetujuan JIT	27
3.4 Perancangan Mekanisme Kontrol Akses.....	28
3.4.1 Perancangan <i>Role-Based Access Control</i> (RBAC).....	29
3.4.2 Perancangan <i>Least Privilege</i> (LP).....	30
3.4.3 Perancangan <i>Just-In-Time</i> (JIT) Access	31

3.5 Arsitektur Tingkat Tinggi (<i>High-Level Architecture</i>).....	33
3.6 Lingkungan Implementasi	36
3.6.1 Kebutuhan Perangkat Keras (<i>Hardware</i>).....	36
3.6.2 Kebutuhan Perangkat Lunak (<i>Software</i>) dan Teknologi	36
3.7 Skenario Pengujian dan Metode Evaluasi	38
3.7.1 Skenario Pengujian <i>Least Privilege</i> (Pembatasan Lingkup)	38
3.7.2 Skenario Pengujian <i>Just-In-Time Access</i> (Pembatasan Durasi).....	39
3.7.3 Skenario Pengujian Simulasi Penyalahgunaan	40
3.7.4 Teknik Analisis dan Evaluasi Hasil	41
DAFTAR PUSTAKA	43

DAFTAR GAMBAR

Gambar 2. 1 RBAC Dasar	13
Gambar 3. 1 Alur Penelitian.....	20
Gambar 3. 2 Mekanisme dan Logika Persetujuan JIT	27
Gambar 3. 3 Mekanisme <i>Ticket-Based Access Control</i>	31
Gambar 3. 4 Perancangan Mekanisme <i>Just-In-Time Access</i>	33
Gambar 3. 5 Arsitektur Tingkat Tinggi (High-Level Architecture)	34

DAFTAR TABEL

Tabel 2. 1 Penelitian Terdahulu.....	7
Tabel 2. 2 Perbandingan Model Kontrol Akses.....	18
Tabel 3. 1 Pengidentifikasian Peran dalam Sistem	23
Tabel 3. 2 Pemetaan Fitur Sistem.....	23
Tabel 3. 3 Identifikasi Fitur Sensitif dan Mekanisme <i>Just-In-Time Access</i>	26
Tabel 3. 4 Perancangan <i>Role-Based Access Control</i> (RBAC).....	29
Tabel 3. 5 Kebutuhan Perangkat Keras (<i>Hardware</i>)	36
Tabel 3. 6 Skenario Pengujian <i>Least Privilege</i>	38
Tabel 3. 7 Skenario Pengujian <i>Just-In-Time Access</i>	39
Tabel 3. 8 Skenario Pengujian Simulasi Penyalahgunaan	40

BAB I

PENDAHULUAN

1.1 Latar Belakang

Dalam sistem digital modern yang mengelola data sensitif, keberadaan pengguna internal merupakan bagian yang tidak terpisahkan dari operasional sistem. Pengguna internal memiliki akses terhadap data dan fungsi tertentu untuk mendukung aktivitas seperti verifikasi akun, pemantauan transaksi, dan penanganan permintaan pengguna (Habeeb Omotunde & Maryam Ahmed, 2023). Akses tersebut diberikan secara sah sebagai bagian dari kebutuhan operasional sistem. Namun, di sisi lain, pengguna internal dengan akses sah juga menjadi salah satu sumber risiko utama dalam keamanan sistem (Usman et al., 2025). Berbeda dengan ancaman eksternal, aktivitas pengguna internal berlangsung dalam lingkup kewenangan yang valid, sehingga penyalahgunaan akses sulit dibedakan dari aktivitas normal. Kondisi ini meningkatkan potensi terjadinya insider threat, yaitu penyalahgunaan akses oleh pihak internal yang memiliki kredensial resmi dalam sistem.

Kasus nyata menunjukkan bahwa penyalahgunaan akses internal merupakan ancaman yang signifikan dalam sistem yang mengelola data sensitif. Salah satu kasus terjadi pada FinWise Bank, di mana seorang mantan pegawai masih memiliki akses ke sistem setelah masa kerja berakhir dan menggunakan akses tersebut untuk mengambil data pelanggan yang berkaitan dengan American First Finance. Insiden ini berdampak pada sekitar 689.000 pengguna dan dilaporkan sebagai pelanggaran data, yang menunjukkan bahwa kegagalan dalam pengelolaan akses internal dapat menyebabkan kebocoran data dalam skala besar (PentaSecurity, 2025).

Kasus lain terjadi pada DBS Bank, di mana seorang pekerja kontrak dengan akses ke sistem internal Customer Relationship Management (CRM) menyalahgunakan hak aksesnya untuk mengambil data nasabah tanpa otorisasi dan membagikannya kepada pihak lain. Dalam laporan resmi disebutkan bahwa pelaku merupakan pengguna internal dengan akses sah, namun melakukan akses di luar kebutuhan tugasnya dan kemudian dijatuhi hukuman pidana. Kasus ini

menegaskan bahwa akses yang tidak dibatasi berdasarkan kebutuhan operasional berpotensi disalahgunakan meskipun diberikan secara sah (The Straitstimes, 2022).

Kedua kasus tersebut menunjukkan pola yang serupa, yaitu bahwa penyalahgunaan tidak terjadi akibat kegagalan autentikasi atau serangan eksternal, melainkan karena kelemahan dalam pengelolaan hak akses setelah proses autentikasi. Pada banyak sistem, kontrol akses masih bersifat statis, di mana pengguna internal diberikan hak akses berdasarkan peran tanpa pembatasan terhadap konteks penggunaan maupun durasi akses. Akibatnya pengguna dapat mengakses data atau fungsi yang tidak selalu diperlukan serta mempertahankan akses tersebut dalam jangka waktu yang tidak terbatas.

Berbagai penelitian telah mengusulkan pendekatan untuk mengatasi permasalahan tersebut, khususnya melalui penerapan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access*. *Least Privilege* membatasi hak akses pengguna hanya pada kebutuhan minimum sesuai tugasnya, sedangkan *Just-In-Time Access* memberikan akses terhadap fungsi sensitif secara sementara berdasarkan kebutuhan. Kombinasi kedua mekanisme ini terbukti dapat mengurangi *standing privilege* serta membatasi potensi penyalahgunaan akses internal.

Namun demikian, sebagian besar implementasi dan penelitian sebelumnya masih berfokus pada level infrastruktur, seperti pengelolaan akses pada server, sistem operasi, database, serta lingkungan IT dan DevOps. Pendekatan tersebut belum banyak memberikan gambaran implementasi pada layer kontrol akses aplikasi, yaitu pada level di mana interaksi langsung antara pengguna internal dan fitur sistem terjadi. Padahal, pada sistem yang mengelola data sensitif, sebagian besar akses terhadap data dan fungsi kritis berlangsung pada layer aplikasi. Oleh karena itu, diperlukan pendekatan yang tidak hanya mengadopsi konsep *Least Privilege* dan *Just-In-Time Access*, tetapi juga mengimplementasikannya secara langsung pada layer kontrol akses aplikasi untuk pengguna internal, sehingga pembatasan lingkup dan durasi akses dapat diterapkan secara lebih kontekstual.

Dalam konteks tersebut, prototipe sistem dompet digital dalam penelitian ini digunakan sebagai media implementasi untuk merepresentasikan sistem yang mengelola data sensitif dan melibatkan pengguna internal dengan hak akses operasional. Berbeda dengan penelitian terdahulu yang umumnya berfokus pada penerapan kontrol akses di level infrastruktur, penelitian ini menitikberatkan pada implementasi mekanisme kontrol akses pada layer aplikasi. Oleh karena itu, prototipe ini digunakan untuk memberikan gambaran bagaimana prinsip *Least Privilege* dan *Just-In-Time Access* diterapkan dalam mengatur akses pengguna internal terhadap data dan fitur sensitif pada level aplikasi secara terstruktur.

Berdasarkan hal tersebut, penelitian ini berfokus pada implementasi mekanisme *Least Privilege* dan *Just-In-Time Access* pada layer kontrol akses pengguna internal dalam prototipe sistem dompet digital. Dengan menggunakan *Role-Based Access Control* (RBAC) sebagai model dasar, penelitian ini menerapkan pembatasan hak akses berbasis *Least Privilege* serta mekanisme akses sementara melalui *Just-In-Time Access*.

Harus diakui bahwa industri finansial skala besar tentu telah menerapkan mekanisme keamanan tingkat lanjut dengan arsitektur dan pendekatan spesifik masing-masing yang dijaga ketat sebagai rahasia perusahaan. Oleh karena itu, prototipe dompet digital dalam penelitian ini sama sekali tidak dirancang untuk menyaingi kecanggihan keamanan platform yang sudah ada, apalagi mengklaim keunggulan teknis melebihi standar industri saat ini. Fokus utamanya berangkat dari kenyataan bahwa implementasi praktis *Least Privilege* dan *Just-In-Time Access* pada *layer* aplikasi komersial masih menjadi entitas tertutup yang sangat minim rujukan literatur terbukanya. Dengan demikian, penelitian ini murni bertujuan untuk mengakademiskan praktik keamanan standar industri tersebut. Melalui prototipe ini, akan digambarkan mekanisme yang umumnya bersifat tertutup akan diterjemahkan ke dalam ranah akademis agar dapat menjadi rujukan teknis dasar yang terbuka, dapat dipelajari, dan diverifikasi secara empiris.

Evaluasi dalam penelitian ini dilakukan melalui pengujian skenario untuk memverifikasi penerapan mekanisme *Least Privilege* dan *Just-In-Time Access* pada sistem. Pengujian dilakukan dengan menjalankan beberapa skenario penggunaan guna memastikan bahwa pembatasan hak akses serta mekanisme akses sementara berjalan sesuai dengan perancangan. Hasil pengujian digunakan untuk menunjukkan bahwa mekanisme kontrol akses yang diterapkan mampu membatasi lingkup dan durasi akses pengguna internal pada level aplikasi.

1.2 Rumusan masalah

Berdasarkan latar belakang yang telah diuraikan, Rumusan masalah dalam penelitian ini adalah sebagai berikut:

- 1) Bagaimana mengidentifikasi kebutuhan kontrol akses pengguna internal melalui pemodelan peran, data sensitif, dan fitur sistem dalam prototipe sistem dompet digital?
- 2) Bagaimana menerapkan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access* dalam membatasi serta mengatur akses terhadap data dan fitur sensitif pada layer kontrol akses pengguna internal sistem?
- 3) Bagaimana mengevaluasi penerapan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access* dalam membatasi hak akses pengguna internal pada prototipe sistem dompet digital?

1.3 Tujuan Penelitian

Mengacu pada rumusan masalah yang telah ditetapkan, Tujuan-tujuan tersebut adalah:

- 1) Mengidentifikasi kebutuhan kontrol akses pengguna internal melalui pemodelan peran, data sensitif, dan fitur sistem dalam prototipe sistem dompet digital.
- 2) Menerapkan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access* dalam membatasi serta mengatur akses terhadap data dan fitur sensitif pada sistem.

- 3) Mengevaluasi penerapan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access* dalam membatasi hak akses pengguna internal pada prototipe sistem dompet digital.

1.4 Manfaat Penelitian

Dengan adanya penelitian ini diharapkan dapat memberikan manfaat sebagai berikut:

A. Manfaat Teoritis

Penelitian ini memberikan kontribusi dalam pengembangan kajian keamanan sistem informasi, khususnya pada implementasi mekanisme kontrol akses pengguna internal melalui penerapan prinsip *Least Privilege* dan *Just-In-Time Access* pada layer aplikasi. Penelitian ini juga memberikan referensi mengenai bagaimana kedua mekanisme tersebut dapat diterapkan secara terstruktur dalam pengelolaan hak akses pengguna internal.

B. Manfaat Praktis

1. Bagi Pengembang Sistem

Penelitian ini memberikan gambaran implementasi mekanisme kontrol akses pengguna internal pada level aplikasi, khususnya dalam membatasi hak akses berdasarkan peran serta mengatur akses terhadap fitur sensitif secara terkontrol.

2. Bagi Organisasi

Penelitian ini dapat menjadi referensi dalam pengelolaan akses pengguna internal, khususnya dalam mengurangi potensi penyalahgunaan akses dengan menerapkan pembatasan lingkup dan durasi akses pada sistem yang mengelola data sensitif.

3. Bagi Peneliti Selanjutnya

Penelitian ini dapat menjadi dasar untuk pengembangan lebih lanjut terkait implementasi mekanisme kontrol akses pada layer aplikasi, baik dengan pendekatan yang lebih kompleks maupun pada lingkungan sistem yang lebih luas.

1.5 Batasan Penelitian

Untuk menjaga fokus dan ketercapaian tujuan penelitian, maka penelitian ini memiliki beberapa batasan sebagai berikut:

- 1) Penelitian ini menggunakan prototipe sistem dompet digital sebagai media implementasi mekanisme kontrol akses pada pengguna internal, dan tidak bertujuan untuk membangun sistem finansial secara lengkap maupun membahas keseluruhan proses bisnis sistem.
- 2) Penelitian difokuskan pada penerapan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access* pada kontrol akses pengguna internal di level aplikasi, serta tidak mencakup penerapan mekanisme keamanan pada level infrastruktur seperti pengelolaan akses pada server, database, maupun sistem operasi.
- 3) Penelitian ini tidak membahas aspek keamanan di luar kontrol akses aplikasi maupun aspek performa sistem, seperti serangan eksternal, keamanan jaringan, keamanan infrastruktur, serta pengukuran kinerja, karena difokuskan pada layer kontrol akses internal dalam konteks technical/logical security.
- 4) Pengujian dilakukan pada lingkungan prototipe, sehingga hasil penelitian tidak secara langsung merepresentasikan implementasi pada sistem produksi berskala nyata.

BAB II

TINJAUAN PUSTAKA

2.1 Penelitian Terkait

Beberapa penelitian terdahulu yang membahas pengendalian akses, *Least Privilege*, serta mekanisme *Just-In-Time Access* telah menjadi landasan dalam perumusan penelitian ini. Penelitian-penelitian tersebut menunjukkan bahwa pembatasan hak akses dan penghapusan akses permanen memiliki peran penting dalam menekan risiko penyalahgunaan hak akses pada sistem yang melibatkan pengguna internal.

Berikut ringkasan dari penelitian-penelitian terdahulu disajikan pada Tabel 2.1.

Tabel 2. 1 Penelitian Terdahulu

No	Peneliti	Judul	Kesimpulan
1.	(Rao, 2025)	Strategic Value of <i>Just-In-Time Access Control</i>	Penerapan <i>Just-In-Time Access</i> dalam kerangka Zero Trust dapat mengurangi risiko insider threat dengan menghilangkan akses permanen
2.	(Nagaraju Velur, 2025)	The Evolution of Enterprise Security Systems in Cloud-native Architectures: From Perimeter-Based to Automated, Granular Models	penerapan prinsip seperti Least Privilege, <i>Just-In-Time Access</i> , dan Zero Trust menjadi kunci dalam meningkatkan keamanan, fleksibilitas, serta efektivitas pengelolaan akses pada lingkungan yang terdistribusi.

3.	(Ajay Benadict Antony Raju, 2021)	Zero Trust Architecture for Financial Institutions	Zero Trust Architecture dengan prinsip Least Privilege dan <i>Just-In-Time Access</i> efektif dalam membatasi akses internal dan meminimalkan risiko insider threat pada sistem yang mengelola data sensitif
4.	(Haber & Rolls, 2020)	<i>Just-In-Time Access</i> Management	Manajemen akses <i>Just-In-Time</i> yang selaras dengan prinsip Least Privilege dan konteks kerja mampu mengurangi <i>standing privilege</i> dan menekan potensi penyalahgunaan akses internal
5.	(Subramanyam, 2025)	Zero Trust in Practice: Enhancing Privileged Access Security with <i>Just-In-Time</i> (JIT) and Self-Service Models	integrasi Least Privilege dan <i>Just-In-Time</i> (JIT) dalam kerangka Zero Trust secara efektif menghilangkan akses permanen, mempersempit attack surface, dan meningkatkan keamanan privileged <i>Access</i> melalui mekanisme akses sementara dan otomatis.
6.	(Vikas Prajapati, 2025)	Role of Identity and Access Management in Zero Trust Architecture for Cloud Security: Challenges and Solutions	Least Privilege membatasi lingkup akses, sedangkan <i>Just-In-Time Access</i> membatasi durasi akses untuk mengurangi risiko penyalahgunaan internal.

Berdasarkan tinjauan pada Tabel 2.1, penelitian-penelitian terdahulu menunjukkan bahwa penerapan prinsip Least Privilege dan mekanisme *Just-In-Time (JIT) Access* memiliki peran penting dalam pengelolaan hak akses yang aman. Namun, celah penelitian yang ada menunjukkan bahwa sebagian besar implementasi masih berfokus pada level infrastruktur (seperti cloud, jaringan, dan server), dan belum banyak yang menyajikan bentuk implementasi teknis secara langsung pada layer kontrol akses aplikasi (application layer).

Berangkat dari celah tersebut, penelitian ini memindahkan fokus implementasi ke dalam level fungsionalitas aplikasi. Pemilihan sistem dompet digital sebagai representasi lingkungan implementasi yang didasarkan pada karakteristik operasionalnya yang secara nyata mengelola data sangat sensitif (seperti riwayat transaksi dan data KYC nasabah), yang rutin diakses oleh staf internal (customer service, admin). Meskipun model *Role-Based Access Control (RBAC)* mungkin telah diterapkan untuk mengelola interaksi staf tersebut, penggunaan RBAC saja dinilai tidak lagi cukup memadai. Hal ini dikarenakan sifat dasar RBAC yang statis tetap menyisakan celah keamanan berupa hak akses yang melekat secara permanen (*standing privilege*) pada akun pengguna internal. Oleh karena itu, perlu ditegaskan bahwa penelitian ini tidak bertujuan untuk membangun sistem dompet digital komersial secara utuh. Sistem ini murni dibangun sebagai prototipe fungsional yang bertindak sebagai media representasi untuk menyimulasikan lingkungan *backend* operasional, sehingga penyelesaian masalah kontrol akses melalui penerapan *Least Privilege* dan *Just-In-Time* dapat diamati secara terfokus.

Meskipun industri finansial berskala besar kemungkinan besar telah menerapkan standar keamanan tingkat lanjut dalam operasional mereka, arsitektur dan implementasi teknis di layer aplikasi tersebut umumnya bersifat tertutup dan menjadi rahasia perusahaan. Akibatnya, rujukan teknis dan literatur akademis terbuka yang membedah bagaimana prinsip *Least Privilege* dan *Just-In-Time Access* dirancang dan dibangun ke dalam bentuk kode pada antarmuka aplikasi masih sangat minim. Oleh karena itu, penelitian ini hadir untuk memodelkan konsep keamanan standar industri tersebut ke dalam ranah akademis yang terbuka. Rancangan prototipe ini memberikan gambaran rujukan

teknis yang dapat diverifikasi mengenai bagaimana mekanisme tersebut dapat dibangun dari dasar.

Untuk memastikan bahwa perancangan ini berjalan sesuai konsep, penelitian ini akan melakukan evaluasi melalui pengujian skenario fungsional. Evaluasi ini difokuskan secara spesifik untuk memverifikasi apakah aturan pembatasan hak akses (*Least Privilege*) dan pemberian akses sementara (*Just-In-Time*) pada prototipe telah berhasil diterapkan sesuai rancangan. Hasil dari penelitian ini diharapkan dapat menjadi bukti implementatif dan referensi akademis mengenai bagaimana kontrol akses dinamis dapat dibangun pada layer aplikasi untuk membatasi ruang lingkup pengguna internal secara efektif.

2.2 Sistem Dompot Digital

Sistem dompet digital (e-wallet) merupakan salah satu bentuk inovasi teknologi finansial (fintech) yang menyediakan layanan penyimpanan instrumen pembayaran, penampungan dana, serta pelaksanaan transaksi keuangan secara elektronik (Kraiwanit et al., 2024). Secara arsitektur perangkat lunak, sistem ini umumnya terbagi menjadi dua sisi utama, yaitu sisi pengguna akhir (front-end) yang digunakan oleh nasabah untuk bertransaksi, dan sisi operasional (back-end) yang dikelola oleh entitas penyedia layanan. Tingginya volume transaksi dan kebutuhan integrasi secara real-time menuntut dompet digital untuk memiliki infrastruktur aplikasi yang andal sekaligus tata kelola operasional yang terstruktur di belakang layar.

Sebagai platform yang menjembatani aktivitas finansial, sistem dompet digital mengelola berbagai klasifikasi data yang bersifat sangat sensitif. Data tersebut mencakup Informasi Identitas Pribadi (Personally Identifiable Information / PII) seperti nomor induk kependudukan dan kontak pengguna, serta data rekam jejak finansial berupa informasi saldo, riwayat mutasi, dan rincian transaksi (Mohamed et al., 2026). Karakteristik data yang memiliki nilai tinggi ini menjadikan sistem dompet digital sebagai entitas yang membutuhkan perlindungan ketat, khususnya pada tata kelola akses terhadap data di dalam ruang lingkup layer aplikasi itu sendiri.

Dalam operasional sehari-hari, pemeliharaan dan pengelolaan ekosistem dompet digital ini sangat bergantung pada interaksi dari pengguna internal, seperti administrator sistem, staf operasional, tim audit, maupun layanan teknis pelanggan (customer service) (Deliu & Moldovan, 2025). Para pengguna internal ini membutuhkan akses ke dalam layer aplikasi back-end untuk menjalankan tugas fungsional yang sah, seperti melakukan verifikasi akun (Know Your Customer / KYC), menangani keluhan transaksi pengguna, hingga memantau laporan keuangan (Gupta et al., 2023). Interaksi intensif antara pengguna internal dengan fitur-fitur sensitif dalam aplikasi inilah yang menuntut adanya mekanisme kontrol akses yang presisi.

Oleh karena itu, dalam konteks penelitian ini, prototipe sistem dompet digital digunakan sebagai media implementasi yang sangat representatif. Prototipe ini tidak dikembangkan untuk memenuhi fungsionalitas bisnis finansial secara menyeluruh, melainkan dirancang khusus untuk mensimulasikan lingkungan operasional *back-end* beserta fitur-fitur administratifnya. Melalui prototipe inilah mekanisme pembatasan hak akses internal dapat diterapkan pada layer aplikasi, sehingga pemodelan peran, data sensitif, dan fitur sistem dapat dievaluasi secara terukur dan relevan.

2.3 Kontrol Akses

Kontrol akses merupakan mekanisme keamanan yang krusial dalam sistem informasi untuk mengatur siapa saja yang diizinkan berinteraksi dengan sumber daya tertentu (Ragothaman et al., 2023). Secara mendasar, kontrol akses bertujuan untuk menjamin integritas dan kerahasiaan data dengan cara membatasi akses hanya kepada pengguna yang memiliki hak sah. Dalam ekosistem perangkat lunak, kontrol akses bekerja sebagai filter yang menentukan apakah sebuah permintaan (*request*) dari pengguna dapat diproses atau ditolak berdasarkan aturan keamanan yang telah ditetapkan sebelumnya (Park et al., 2025).

Secara teknis, proses kontrol akses melibatkan tiga tahapan utama, yaitu identifikasi, autentikasi, dan otorisasi. Identifikasi merupakan tahap awal di mana pengguna menyatakan identitasnya kepada sistem (seperti penggunaan

username). Autentikasi adalah proses verifikasi untuk membuktikan keabsahan identitas tersebut (misalnya melalui kata sandi). Setelah identitas terverifikasi, tahap otorisasi menentukan cakupan tindakan atau data apa saja yang boleh diakses oleh pengguna tersebut. Penelitian ini menitikberatkan pada tahap otorisasi, di mana pembatasan hak akses dilakukan secara lebih spesifik pada fungsionalitas di dalam aplikasi (Kumar, 2025).

Terdapat beberapa model kontrol akses yang umum diterapkan dalam pengembangan sistem informasi. Beberapa di antaranya adalah *Discretionary Access Control* (DAC) yang memberikan wewenang penuh kepada pemilik data untuk mengatur akses, serta *Mandatory Access Control* (MAC) yang menggunakan klasifikasi keamanan ketat dari pusat sistem. Selain itu, terdapat pula *Attribute-Based Access Control* (ABAC) yang memberikan akses berdasarkan karakteristik atau atribut pengguna dan lingkungan (Farhadighalati et al., 2025). Namun, di antara berbagai model tersebut, *Role-Based Access Control* (RBAC) menjadi salah satu yang paling luas digunakan karena kemudahannya dalam manajemen hak akses berdasarkan struktur organisasi atau peran fungsional.

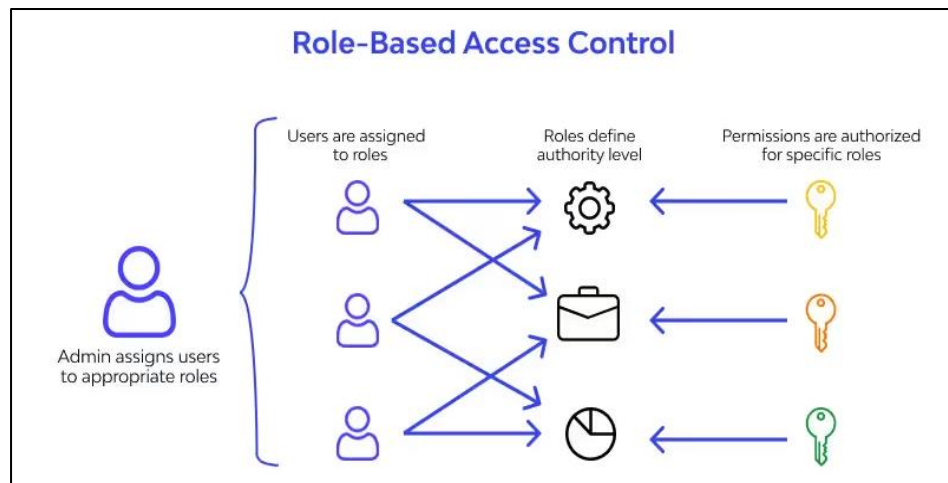
Implementasi kontrol akses pada *layer* aplikasi menjadi fokus utama dalam penelitian ini guna melindungi data sensitif secara lebih kontekstual. Berbeda dengan kontrol akses pada *layer* jaringan atau infrastruktur, kontrol akses aplikasi memungkinkan pengaturan yang lebih detail terhadap fitur-fitur spesifik di dalam sistem, seperti akses ke tombol transaksi atau tampilan data mutasi keuangan. Dengan menerapkan kontrol akses yang tepat di level aplikasi, sistem dapat memastikan bahwa setiap aktivitas operasional yang dilakukan oleh pengguna internal tetap berada dalam batasan teknis yang telah ditentukan oleh kebijakan organisasi.

2.4 Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) merupakan model pengontrolan akses yang berpusat pada penetapan wewenang berdasarkan peran (*role*) pengguna di dalam suatu organisasi, bukan berdasarkan identitas individu secara langsung. Dalam model ini, hak akses atau *privilege* dikaitkan dengan peran

tertentu, dan pengguna kemudian ditugaskan pada peran yang sesuai dengan tanggung jawab serta fungsionalitas pekerjaan mereka (Waheed et al., 2025). Pendekatan ini sangat efisien diterapkan pada aplikasi skala menengah hingga besar, seperti operasional back-end sistem dompet digital, karena menyederhanakan proses pengelolaan keamanan ketika terjadi rotasi staf atau perubahan tugas administratif.

Secara struktural, model dasar RBAC beroperasi melalui interaksi tiga elemen utama: Pengguna (*User*), Peran (*Role*), dan Izin Akses (*Permission*). *User* merepresentasikan entitas manusia yang berinteraksi dengan sistem, sedangkan *Role* mewakili fungsi pekerjaan atau level otoritas tertentu, misalnya peran sebagai "Auditor" atau "Customer Service". Sementara itu, *Permission* adalah persetujuan teknis untuk mengeksekusi operasi tertentu terhadap data, seperti hak untuk membaca riwayat transaksi atau menyetujui penarikan dana (Atlam & Yang, 2025). Dengan memisahkan penugasan *User-to-Role* dan *Role-to-Permission*, sistem dapat mengelompokkan hak akses secara terpusat tanpa harus mengonfigurasi setiap pengguna secara individual. Ilustrasi gambaran umum RBAC dasar dapat dilihat pada gambar 2.1.



Gambar 2. 1 RBAC Dasar

Meskipun RBAC menawarkan kemudahan dalam administrasi dan skalabilitas, model dasar ini memiliki keterbatasan krusial ketika diimplementasikan pada lingkungan yang mengelola data sangat sensitif. Kelemahan utama RBAC terletak pada sifatnya yang statis dan cenderung

menghasilkan *standing privileges*, yaitu kondisi di mana hak akses selalu melekat pada pengguna secara permanen (Ebad & Amara, 2026). Ketika seorang pengguna internal diberikan suatu peran, ia akan terus memiliki akses terhadap seluruh izin dalam peran tersebut setiap saat, terlepas dari apakah ia sedang membutuhkannya untuk menyelesaikan sebuah tugas spesifik pada waktu tersebut atau tidak.

Sifat hak akses statis yang melekat secara terus-menerus ini memperbesar celah kerentanan terhadap penyalahgunaan wewenang sah oleh pengguna internal. Oleh karena itu, dalam perancangan kontrol akses aplikasi yang modern, implementasi RBAC murni dinilai tidak lagi mencukupi (Bates et al., 2025). Model RBAC perlu dijadikan sebagai struktur dasar yang kemudian diperketat dengan pembatasan wewenang yang lebih granular, serta dikombinasikan dengan kontrol dinamis berbasis waktu dan konteks kebutuhan. Keterbatasan struktural RBAC inilah yang menjadi dasar pijakan untuk mengintegrasikan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access*.

2.5 Least Privilege

Prinsip *Least Privilege* (LP) adalah landasan keamanan informasi yang menetapkan bahwa setiap pengguna, proses, maupun sistem hanya boleh diberikan hak akses seminimal mungkin yang benar-benar diperlukan untuk menyelesaikan suatu tugas spesifik dalam jangka waktu tertentu (Plachkinova & Knapp, 2023). Prinsip ini bertujuan untuk membatasi ruang lingkup kerusakan yang dapat terjadi, baik akibat kesalahan manusia (*human error*) maupun penyalahgunaan akses yang sah. Dalam implementasi pada layer aplikasi, *Least Privilege* menuntut pembatasan akses yang sangat granular, di mana hak akses tidak lagi diberikan secara luas berdasarkan posisi jabatan, melainkan berdasarkan kebutuhan fungsional paling dasar dari sebuah instruksi kerja.

Sering kali terdapat kerancuan yang menganggap bahwa penerapan *Role-Based Access Control* (RBAC) secara otomatis telah memenuhi prinsip *Least Privilege*. Namun, secara fundamental keduanya memiliki entitas yang berbeda, RBAC adalah sebuah mekanisme administratif untuk

mengelompokkan hak akses, sedangkan *Least Privilege* adalah prinsip keamanan yang mengatur kedalaman dan batasan dari hak akses tersebut (Olorunlana, 2025). Tanpa penerapan *Least Privilege* yang ketat, model RBAC cenderung bersifat terlalu luas (*over-privileged*), di mana sebuah peran (*role*) diberikan sekumpulan izin akses yang mencakup seluruh fungsi dalam suatu departemen, padahal pengguna mungkin hanya membutuhkan satu atau dua fungsi saja untuk menyelesaikan tugas hariannya (Plachkinova & Knapp, 2023).

Perbedaan krusial lainnya terletak pada tingkat granularitas kontrolnya. Dalam RBAC tradisional, kontrol akses sering kali berhenti pada level "siapa boleh mengakses fitur apa". Sementara itu, *Least Privilege* masuk lebih dalam ke level "data apa yang boleh diakses dan tindakan minimal apa yang diizinkan" (Rose et al., 2020). Sebagai contoh, dalam sistem dompet digital, seorang staf layanan pelanggan mungkin diberikan peran (*role*) untuk melihat data transaksi pengguna. Namun, berdasarkan prinsip LP, staf tersebut hanya diizinkan melihat data transaksi yang sedang dikeluhkan oleh pengguna, bukan seluruh riwayat transaksi global, dan hanya memiliki izin baca (*read-only*) tanpa izin untuk mengubah data tersebut.

Penerapan prinsip *Least Privilege* pada layer aplikasi dalam penelitian ini berfungsi untuk membedah kembali peran-peran statis dalam RBAC menjadi izin akses yang lebih mikro dan spesifik. Dengan membatasi hak akses pada level fungsionalitas yang paling rendah, potensi paparan data sensitif dapat diminimalisir. Namun, meskipun LP mampu membatasi lingkup akses, prinsip ini tetap menyisakan celah jika akses tersebut bersifat permanen. Oleh karena itu, prinsip *Least Privilege* perlu dikolaborasikan dengan mekanisme kontrol akses dinamis berbasis waktu guna mencapai tingkat keamanan yang lebih komprehensif pada sistem dompet digital.

2.6 Just-In-Time Access

Just-In-Time (JIT) Access adalah mekanisme kontrol akses dinamis yang memberikan hak akses kepada pengguna hanya pada saat dibutuhkan dan untuk jangka waktu yang terbatas (Behringer & Baumann, 2025). Prinsip utama dari JIT adalah penghapusan *standing privileges*, yaitu kondisi di mana pengguna

memiliki hak akses administratif atau sensitif yang selalu aktif setiap saat (Olaide et al., 2025). Dengan menerapkan JIT, hak akses tidak lagi bersifat permanen, melainkan diberikan secara temporer berdasarkan permintaan atau pemicu tertentu, dan akan dicabut secara otomatis setelah tugas selesai atau durasi waktu yang ditetapkan telah berakhir.

Mekanisme JIT bekerja dengan cara meminimalkan jendela kerentanan pada sistem. Dalam operasional aplikasi, seorang pengguna internal mungkin memiliki peran yang sah, namun ia tidak selalu membutuhkan seluruh hak akses administratif tersebut dalam aktivitas rutinnnya. Melalui JIT, sistem menyediakan jalur di mana pengguna harus melewati proses verifikasi atau persetujuan tambahan sebelum mendapatkan peningkatan hak akses sementara. Hal ini memastikan bahwa hak akses tingkat tinggi hanya ada pada durasi yang sangat singkat, sehingga secara signifikan memperkecil *attack surface* atau ruang lingkup yang dapat disalahgunakan.

Dalam konteks layer aplikasi dompet digital, implementasi JIT memungkinkan pengelolaan akses terhadap fitur sensitif dilakukan secara lebih kontekstual. Sebagai contoh, ketika seorang staf layanan pelanggan perlu mengakses data transaksi detail untuk menangani keluhan pengguna, sistem akan memberikan akses tersebut hanya untuk durasi waktu tertentu, misalnya 15 menit. Setelah waktu tersebut habis, *session* atau izin akses tersebut akan kedaluwarsa secara otomatis di level aplikasi. Pendekatan ini memberikan perlindungan tambahan dibandingkan kontrol akses tradisional yang membiarkan akun administratif memiliki akses penuh selama staf tersebut masih berstatus karyawan aktif.

Integrasi antara JIT dengan prinsip *Least Privilege* dan model RBAC membentuk sebuah ekosistem keamanan yang komprehensif pada layer kontrol akses pengguna internal. RBAC berperan dalam menyediakan struktur peran yang terorganisir, *Least Privilege* memastikan setiap peran hanya memiliki izin fungsional minimum, dan JIT menyempurnakannya dengan memberikan batasan durasi terhadap izin tersebut. Sinergi ketiga elemen ini memungkinkan prototipe sistem dompet digital dalam penelitian ini untuk memiliki mekanisme

kontrol akses yang adaptif, di mana setiap interaksi pengguna internal terhadap data sensitif dibatasi tidak hanya pada lingkup fungsinya, tetapi juga pada urgensi dan waktu penggunaannya.

2.7 Relevansi pada Sistem Dompot digital

Pemilihan sistem dompet digital sebagai lingkungan implementasi dalam penelitian ini didasarkan pada karakteristik operasionalnya yang sangat krusial dan rentan terhadap risiko penyalahgunaan wewenang internal. Sebagai platform layanan finansial, dompet digital mengelola volume data yang sangat sensitif, termasuk data transaksi keuangan, saldo pengguna, hingga dokumen identitas pribadi yang dikumpulkan melalui proses *Know Your Customer* (KYC) seperti foto KTP dan swafoto. Data-data kritikal ini secara rutin harus diakses oleh pengguna internal, seperti staf *customer service* atau tim verifikator, untuk keperluan operasional harian. Tingginya nilai informasi yang berada di dalam ekosistem ini menjadikannya lingkungan yang paling relevan dan mendesak untuk dilindungi melalui pembatasan akses yang sangat ketat di level aplikasi.

Dalam konteks penelitian ini, sistem dompet digital tidak dikembangkan sebagai sebuah produk perangkat lunak finansial yang utuh secara bisnis (komersial), melainkan dirancang sebagai prototipe atau media representasi. Prototipe ini difokuskan secara eksklusif pada layer *back-end* administratif guna menyimulasikan bagaimana interaksi antara pengguna internal dengan data-data sensitif tersebut terjadi. Melalui lingkungan tiruan yang terkontrol ini, mekanisme *Role-Based Access Control* (RBAC) dapat dibangun sebagai fondasi dasar, yang kemudian diuji kemampuannya ketika diintegrasikan dengan prinsip keamanan tingkat lanjut. Dengan demikian, prototipe ini bertindak sebagai *testbed* yang valid untuk membuktikan visibilitas penerapan kontrol akses dinamis pada layer aplikasi.

Melalui penerapan prinsip *Least Privilege* dan mekanisme *Just-In-Time Access* pada representasi sistem dompet digital ini, diharapkan dapat tercipta sebuah arsitektur kontrol akses yang jauh lebih mumpuni dibandingkan model konvensional. Penerapan kedua mekanisme tersebut ditujukan untuk menghilangkan *standing privileges* atau hak akses administratif yang melekat

secara permanen pada akun pengguna internal. Hasil akhir dari implementasi ini diharapkan mampu memberikan gambaran arsitektur yang komprehensif mengenai bagaimana sistem dapat membatasi cakupan izin pengguna internal hanya pada fungsi yang mutlak diperlukan (melalui *Least Privilege*), serta membatasi durasi akses tersebut hanya saat tugas operasional sedang dieksekusi (melalui *Just-In-Time Access*), sehingga potensi kebocoran data dari entitas internal dapat diminimalisir secara proaktif. Untuk gambaran setelah penerapan dapat dilihat pada tabel 2.2.

Tabel 2. 2 Perbandingan Model Kontrol Akses

Aspek	Sebelum Penerapan	Setelah LP & JIT
Lingkup akses	Luas berdasarkan role	Minimum sesuai tugas
Status akses	Aktif permanen	Aktif saat dibutuhkan
Akses data sensitif	Selalu tersedia	Terbatas pada Konteks
Aktivasi fitur sensitif	Langsung setelah login	Perlu aktivasi sementara
Durasi akses	Selama sesi login	Berbasis waktu/tugas
Risiko Penyalahgunaan	Lebih tinggi	Lebih terkendali

Berdasarkan perbandingan tersebut, penerapan prinsip *Least Privilege* dan *Just-In-Time Access* menunjukkan perubahan signifikan pada mekanisme kontrol akses internal, khususnya dalam pembatasan lingkup dan durasi akses pengguna internal terhadap data serta fungsi sensitif sistem. Perubahan ini menjadi dasar evaluasi pada penelitian ini, yang difokuskan pada evaluasi sesudah penerapan kedua prinsip tersebut.

BAB III

METODE PENELITIAN

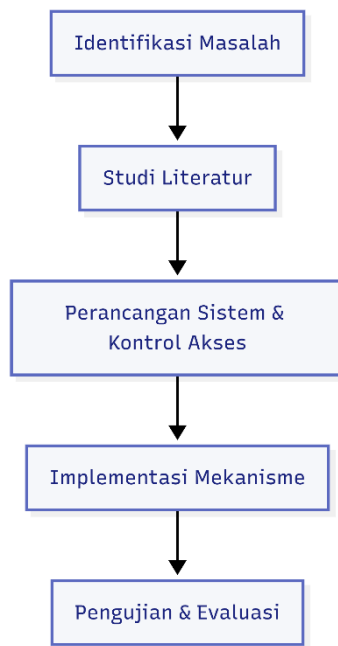
3.1 Pendekatan Penelitian

Penelitian ini merupakan penelitian terapan yang berfokus pada perancangan, implementasi, serta evaluasi mekanisme keamanan sistem informasi. Secara spesifik, penelitian ini menggunakan pendekatan berbasis prototipe (*prototype-based approach*) untuk menyimulasikan lingkungan operasional *back-end* pada sistem dompet digital. Prototipe ini difungsikan sebagai media representasi guna menerapkan dan mengevaluasi kebijakan kontrol akses internal, tanpa bertujuan untuk membangun sistem finansial berskala komersial yang utuh.

Fokus utama dalam penelitian ini dibatasi secara ketat pada layer kontrol akses aplikasi (*application Access Control layer*). Penelitian ini mengeksplorasi bagaimana kelemahan model otorisasi statis, seperti *Role-Based Access Control* (RBAC) yang menghasilkan *standing privileges*, dapat diatasi melalui penerapan prinsip *Least Privilege* dan mekanisme *Just-In-Time* (JIT) *Access*. Perlu ditegaskan bahwa evaluasi pada penelitian ini dititikberatkan pada logika otorisasi sistem dan pengaturan hak akses pengguna internal (seperti administrator atau staf layanan pelanggan) terhadap data sensitif (misalnya data KYC dan mutasi saldo). Penelitian ini tidak mencakup pengujian pada level infrastruktur, keamanan jaringan (*network security*), maupun evaluasi performa operasional layanan pelanggan seperti *response time*. Pendekatan ini dipilih untuk menjaga konsistensi variabel yang diuji, sehingga efektivitas perubahan kebijakan hak akses dapat diamati dan dievaluasi secara terfokus.

3.2 Alur Penelitian.

Untuk menjaga agar proses perancangan dan evaluasi berjalan secara sistematis dan terarah, penelitian ini dilaksanakan melalui lima tahapan utama. Alur tahapan penelitian ini dapat dilihat pada Gambar 3.1.



Gambar 3. 1 Alur Penelitian

Adapun rincian dari masing-masing tahapan pada Gambar 3.1 adalah sebagai berikut:

1. Identifikasi Masalah: Tahap awal ini dilakukan untuk mengidentifikasi celah keamanan pada sistem informasi, khususnya terkait risiko *insider threat* yang muncul akibat hak akses permanen (*standing privileges*) pada pengguna internal di lingkungan pengelola data sensitif, seperti dompet digital.
2. Studi Literatur: Melakukan kajian mendalam terhadap referensi akademis, jurnal penelitian terdahulu, serta standar keamanan (seperti panduan NIST) yang berkaitan dengan arsitektur dompet digital, model kontrol akses, prinsip *Least Privilege*, dan mekanisme *Just-In-Time Access*.
3. Perancangan Sistem dan Kontrol Akses: Merancang model arsitektur logika untuk prototipe dompet digital. Tahap ini mencakup pemetaan struktur peran (*Role-Based Access Control*), perumusan aturan pembatasan akses spesifik berbasis *Least*

Privilege, serta merancang alur kerja (*flowchart*) untuk permintaan dan pencabutan hak akses sementara (*Just-In-Time*).

4. Implementasi Mekanisme: Menerapkan hasil rancangan logika kontrol akses ke dalam bentuk kode pada *layer* otorisasi di prototipe aplikasi. Pada tahap ini, mekanisme pembatasan lingkup dan durasi hak akses diprogram agar dapat beroperasi sesuai dengan batasan desain.
5. Pengujian dan Evaluasi: Tahap akhir berupa pengujian fungsional berbasis skenario (*scenario-based testing*). Evaluasi dilakukan dengan membandingkan respons sistem pada saat akses ditolak, akses sementara diberikan, dan akses telah kedaluwarsa, guna memverifikasi apakah integrasi *Least Privilege* dan JIT telah berjalan sesuai dengan tujuan penelitian.

3.3 Analisis Sistem dan Kebutuhan Kontrol Akses

Tahapan analisis ini bertujuan untuk memetakan arsitektur fungsional pada *Access Control Layer* di dalam prototipe dompet digital. Prototipe ini tidak memuat fungsionalitas transaksi finansial yang kompleks, melainkan difokuskan secara eksklusif pada fitur layanan pelanggan dan manajemen akun untuk menguji efektivitas penerapan *Least Privilege* (LP) dan *Just-In-Time* (JIT) *Access*.

3.3.1 Identifikasi Pengguna Internal

Dalam ekosistem operasional dompet digital komersial, entitas "pengguna internal" sejatinya mencakup berbagai macam peran struktural (seperti *Finance*, *Compliance*, *Auditor*, dan lainnya). Namun, dikarenakan penelitian ini menggunakan pendekatan prototipe fungsional yang berfokus secara spesifik pada pengujian efektivitas *Access Control Layer*, maka implementasi peran pengguna internal dibatasi pada dua peran yang dinilai paling representatif.

Pemilihan dua peran ini didasarkan pada tingkat eksposur operasional terhadap data sensitif nasabah dan kebutuhan pemisahan wewenang (*Separation*

of Duties). Identifikasi peran yang digunakan dalam batasan prototipe ini diuraikan pada Tabel 3.1.

Tabel 3. 1 Pengidentifikasian Peran dalam Sistem

No	Peran (Role)	Deskripsi Hak Akses Dasar	Keterlibatan
1.	Customer Service (CS)	Menangani tiket keluhan pelanggan. Menjadi fokus utama penerapan pembatasan akses data (<i>Least Privilege</i>) dan waktu (JIT Access).	Sebagai Fokus Utama karena memiliki frekuensi interaksi tertinggi dengan keluhan dan data sensitif nasabah
2.	Administrator	Mengelola konfigurasi back-end dan manajemen akun CS. Tidak memiliki akses langsung ke tiket komplain harian nasabah.	Pendukung (Hanya sebagai pengelola sistem, tidak mengeksekusi JIT).

Melalui klasifikasi peran tersebut, penelitian ini dapat mensimulasikan interaksi antara pihak pengelola otoritas (*Administrator*) dan pihak pelaksana operasional (*Customer Service*). Pemisahan wewenang ini menjadi fondasi utama untuk memastikan bahwa kontrol akses tidak terpusat pada satu entitas saja, sehingga mekanisme *Least Privilege* dan *Just-In-Time Access* dapat diuji secara objektif dalam membatasi ruang gerak pengguna internal sesuai dengan tanggung jawabnya.

3.3.2 Pemetaan Fitur Sistem dan Penerapan *Least Privilege*

Untuk mencegah hak akses permanen yang berlebihan (*standing privileges*), sistem menerapkan kontrol akses berbasis konteks tiket (*Ticket-Based Access Control*). Pemetaan Fitur Sistem dan Penerapan *Least Privilege*

dalam membatasi akses CS terhadap fitur dan data sistem dapat dilihat pada Tabel 3.2.

Tabel 3. 2 Pemetaan Fitur Sistem

No	Modul / Fitur Sistem	Akses Default Konvensional (Tanpa LP)	Kondisi Setelah Diterapkan <i>Least Privilege</i>
1.	Melihat Daftar Tiket	CS dapat melihat seluruh tiket masuk.	CS hanya dapat melihat tiket yang ditugaskan kepadanya (<i>Assigned to Me</i>).
2.	Melihat Data Pribadi (KYC)	CS dapat melakukan pencarian data seluruh nasabah di <i>database</i> .	CS tidak dapat melakukan pencarian global. CS hanya dapat melihat data nasabah yang terikat pada ID Tiket yang sedang dibuka.
3.	Melihat Riwayat Mutasi	CS dapat melihat seluruh transaksi nasabah kapan saja.	Akses mutasi dibatasi hanya pada nasabah dengan tiket aktif (<i>Open</i>) yang relevan.
4.	Reset Kata Sandi (Password)	CS dapat langsung mereset kata sandi nasabah kapan saja	Aksi dikunci (<i>default deny</i>). Hanya dapat dilakukan setelah

			aktivasi <i>Just-In-Time Access</i> berbasis tiket aktif, dengan durasi terbatas (± 15 menit).
5.	Membuka Blokir Akun	CS dapat membuka blokir akun secara langsung tanpa batasan konteks.	Hanya dapat dilakukan melalui mekanisme JIT dengan validasi tiket (<i>Assigned & Open</i>), dan akses dicabut otomatis setelah sesi berakhir.
6.	Perubahan Email Utama	CS dapat mengganti email nasabah tanpa pembatasan tambahan.	Memerlukan aktivasi JIT dan hanya tersedia selama sesi terbatas. Semua perubahan tercatat dalam <i>audit log</i>.
7.	Reset / Ubah PIN	CS dapat mengubah PIN nasabah kapan saja.	Dibatasi melalui JIT Access, hanya untuk tiket terkait, dengan verifikasi tambahan dan <i>auto-revoke</i>.

8.	Akses Log Aktivitas Nasabah	CS dapat melihat seluruh aktivitas akun nasabah.	Dibatasi hanya untuk investigasi pada tiket aktif, dan hanya sebagian data yang ditampilkan
9.	Ekspor Data Nasabah	CS dapat mengekspor data kapan saja.	Fitur dinonaktifkan atau dibatasi ketat hanya untuk Administrator. Tidak tersedia untuk CS.

Penjelasan pada tabel di atas menunjukkan perbedaan mendasar antara sistem keamanan biasa dengan sistem yang menerapkan pembatasan ketat. Dengan aturan ini, setiap petugas peran *Customer Service* tidak lagi memiliki akses bebas ke seluruh data nasabah setiap saat. Akses mereka kini sepenuhnya bergantung pada tugas atau tiket yang sedang dikerjakan. Hal ini bertujuan untuk memastikan bahwa fungsi-fungsi penting di dalam aplikasi hanya bisa terbuka apabila ada alasan operasional yang jelas, sehingga keamanan data nasabah lebih terjaga dari risiko penyalahgunaan internal.

3.3.3 Identifikasi Fitur Sensitif dan Logika *Just-In-Time Access*

Selain pembatasan data (LP), sistem memiliki fitur eksekusi yang diklasifikasikan sebagai fitur sensitif. Fitur ini dikunci secara *default* dan hanya dapat diakses menggunakan mekanisme *JIT Access*. Rincian fitur sensitif tersebut dijabarkan pada Tabel 3.3.

Tabel 3. 3 Identifikasi Fitur Sensitif dan Mekanisme *Just-In-Time Access*

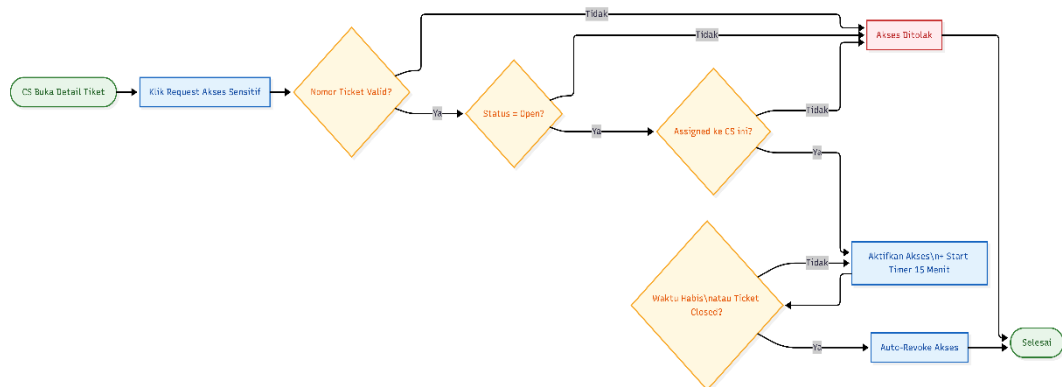
No	Kategori Fitur Sensitif	Tindakan Eksekusi Sistem	Durasi JIT (Batas Sesi)	Mekanisme Kontrol
1.	Manajemen Kredensial	1. Reset Kata Sandi (<i>Password</i>) 2. Melakukan Pembaruan/Perubahan <i>Email</i> Utama 3. Reset / Ubah PIN	15 Menit	Aktivasi berbasis tiket (<i>Assigned & Open</i>), <i>auto-expire</i> , dan pencatatan <i>audit log</i> .
2.	Modifikasi Status Akun	1. Membuka Blokir Akun (<i>Unblock Account</i>) 2. Menangguhkan Akun (<i>Suspend Account</i>)	15 Menit	Validasi konteks tiket, <i>session-based access</i> , dan <i>auto-revoke</i> saat tiket selesai (<i>Closed</i>).
3.	Akses Data Sensitif Tambahan	1. Melihat detail KYC lengkap 2. Melihat riwayat transaksi penuh	10–15 Menit	Akses sementara berbasis kebutuhan investigasi, dengan pembatasan tampilan (<i>data masking</i>)

				sebagian) dan logging.
--	--	--	--	---------------------------

Pembagian kategori fitur sensitif dan batasan durasi di atas menjadi dasar utama dalam sistem untuk menjaga keamanan data nasabah. Dengan adanya batas waktu sesi (10–15 menit), petugas tidak lagi memiliki akses tetap yang terbuka setiap saat ke fungsi-fungsi penting tersebut. Setelah durasi waktu berakhir atau tugas pada tiket dinyatakan selesai, sistem akan secara otomatis mencabut hak akses petugas. Hal ini memastikan bahwa setiap tindakan yang dilakukan oleh pengguna internal selalu memiliki alasan yang kuat, waktu yang terbatas, dan terekam sepenuhnya dalam log aktivitas sistem.

3.3.4 Mekanisme dan Logika Persetujuan JIT

Untuk menjaga kelancaran operasional sistem, mekanisme JIT *Access* pada fitur sensitif di atas tidak memerlukan persetujuan manual dari Administrator, melainkan diotomatisasi oleh *Access Control Layer* pada middleware dengan logika verifikasi seperti pada gambar 3.2.



Gambar 3. 2 Mekanisme dan Logika Persetujuan JIT

Alur mekanisme JIT *Access* yang ditunjukkan pada Gambar 3.X dirancang dengan logika verifikasi sebagai berikut:

- Pemicu (Trigger), Proses dimulai ketika Customer Service (CS) menekan tombol “*Request Akses Eksekusi*” pada halaman detail tiket nasabah.

- Validasi Sistem (Auto-Approval Logic), Middleware melakukan verifikasi secara *real-time* terhadap konteks permintaan dengan mengevaluasi tiga kondisi utama:

1. Validitas *Ticket ID* pada database
2. Status tiket masih dalam kondisi *Open*
3. Kesesuaian penugasan tiket dengan pengguna ($Assigned_CS_ID = Current_User_ID$)

Apabila salah satu kondisi tidak terpenuhi, sistem akan menolak permintaan akses (*Access Denied*) dan mencatat aktivitas tersebut sebagai log anomali.

- Pemberian Akses Sementara (Grant), jika seluruh kondisi valid, sistem akan memberikan eskalasi hak akses secara sementara dengan Mengaktifkan fitur eksekusi sensitif dan Memulai *countdown timer* (± 15 menit) sebagai batas durasi akses.
- Pencabutan Otomatis (Auto-Revoke), Akses yang telah diberikan akan dicabut secara otomatis apabila waktu akses telah melewati batas (*expired*) dan Status tiket berubah menjadi *Closed/Resolved*

Mekanisme ini menunjukkan bahwa kontrol akses tidak hanya ditentukan oleh identitas pengguna, tetapi juga oleh konteks operasional dan durasi akses. Dengan demikian, sistem mampu mengurangi risiko penyalahgunaan hak akses sensitif melalui penerapan kontrol yang bersifat dinamis dan terukur.

3.4 Perancangan Mekanisme Kontrol Akses

Perancangan mekanisme kontrol akses pada sistem ini berfungsi sebagai lapisan validasi utama terhadap setiap permintaan (*request*) yang masuk ke *backend API*. Mekanisme ini memastikan bahwa hanya pengguna yang memiliki hak akses yang sesuai yang dapat menjalankan operasi tertentu.

Pendekatan yang digunakan bersifat berlapis (*layered Access Control*), terdiri dari:

1. *Role-Based Access Control* (RBAC) sebagai kontrol identitas dan peran.
2. *Least Privilege* (LP) sebagai pembatas ruang lingkup.
3. *Just-In-Time* (JIT) *Access* sebagai pembatas durasi akses fitur sensitif.

Ketiga mekanisme ini diimplementasikan pada level *middleware* sehingga setiap request akan melewati proses validasi yang konsisten sebelum mencapai endpoint.

3.4.1 Perancangan *Role-Based Access Control* (RBAC)

Sebagai lapisan pertama, sistem menerapkan model RBAC untuk memastikan bahwa hanya pengguna internal yang terautentikasi dan memiliki peran sah yang dapat berinteraksi dengan *dashboard back-end*. Pemetaan izin dasar pada level peran dirancang pada Tabel 3.4.

Tabel 3. 4 Perancangan *Role-Based Access Control* (RBAC)

No	Role	Permission Utama	Endpoint Terkait	Batasan Akses
1.	Customer Service (CS)	view_assigned_tickets, request_jit_access	/cs, /tickets, /jit, /request	Tidak dapat mengakses konfigurasi sistem
2.	Administrator	manage_users, manage_roles, view_system_logs	/admin, /role, /settings	Tidak dapat mengakses data nasabah dan tiket

Melalui pemetaan yang jelas antara peran, *permission*, dan endpoint, setiap permintaan dapat difilter sejak tahap awal sehingga mencegah akses tidak sah sebelum memasuki lapisan kontrol lanjutan seperti *Least Privilege* dan *Just-In-Time Access*. Dengan demikian, RBAC berperan sebagai fondasi utama dalam menjaga konsistensi dan keamanan alur otorisasi sistem.

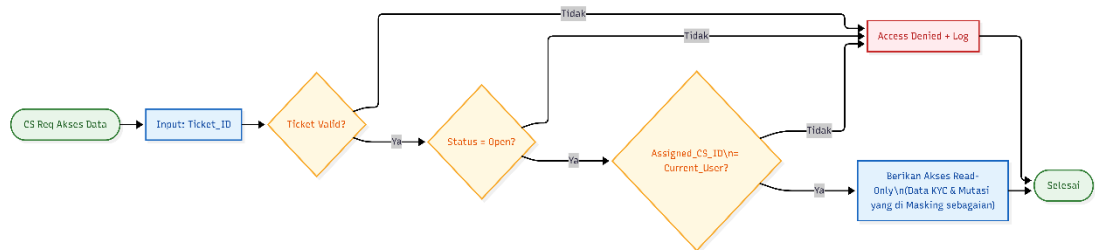
3.4.2 Perancangan *Least Privilege* (LP)

Lapisan kedua berfokus pada pembatasan akses fitur serta cakupan data yang dapat diakses oleh Customer Service (CS). Pendekatan ini dirancang untuk memastikan bahwa CS hanya dapat mengakses data yang relevan dengan tugas yang sedang ditangani, sehingga meminimalkan risiko paparan data secara luas (*standing privileges*). Untuk mencegah akses global terhadap seluruh data pengguna, sistem tidak menyediakan izin *view_all_users*. Sebagai gantinya, diterapkan mekanisme *Ticket-Based Access Control* pada middleware otorisasi. Mekanisme ini menggunakan logika kondisional untuk memverifikasi apakah suatu permintaan akses data diperbolehkan atau tidak.

Adapun aturan kondisional yang diterapkan adalah sebagai berikut:

1. Ketika CS membuka detail profil nasabah atau riwayat mutasi, middleware akan memeriksa parameter Nomor Tiket (*Ticket_ID*) yang disertakan dalam permintaan.
2. Sistem kemudian mencocokkan data pada database dengan ketentuan:
 - Tiket berada dalam status aktif (*Status == "Open"*)
 - Tiket tersebut secara sah ditugaskan kepada CS yang sedang login (*Assigned_CS_ID == Current_User_ID*).
3. Apabila salah satu kondisi tidak terpenuhi, maka middleware akan menolak permintaan akses (*Access Denied*) serta mencatat kejadian tersebut sebagai anomali ke dalam log sistem untuk keperluan audit dan monitoring.

Seluruh alur proses tersebut divisualisasikan dalam diagram pada gambar 3.3.



Gambar 3. 3 Mekanisme *Ticket-Based Access Control*

Berdasarkan diagram tersebut, dapat disimpulkan bahwa mekanisme *Least Privilege* yang diterapkan mampu membatasi akses data secara kontekstual dan dinamis, bergantung pada validitas tiket serta kesesuaian identitas pengguna. Pendekatan ini tidak hanya meningkatkan keamanan sistem dengan mengurangi risiko penyalahgunaan akses, tetapi juga memastikan setiap aktivitas akses dapat ditelusuri melalui pencatatan log yang sistematis. Dengan demikian, prinsip *Least Privilege* dapat diimplementasikan secara efektif dalam mendukung kontrol akses yang aman dan terukur.

3.4.3 Perancangan *Just-In-Time (JIT) Access*

Lapisan ketiga dirancang untuk melindungi endpoint dengan tingkat sensitivitas tinggi, khususnya fitur "Modifikasi Status Akun" dan "Pemulihan Kredensial". Hak akses untuk mengeksekusi fitur-fitur tersebut tidak diberikan secara default, melainkan hanya diaktifkan secara sementara berdasarkan kebutuhan operasional. Perancangan mekanisme *Just-In-Time (JIT) Access* menggunakan pendekatan persetujuan otomatis (auto-approval) berbasis sistem, guna menjaga keseimbangan antara keamanan dan efisiensi dalam penanganan layanan pelanggan.

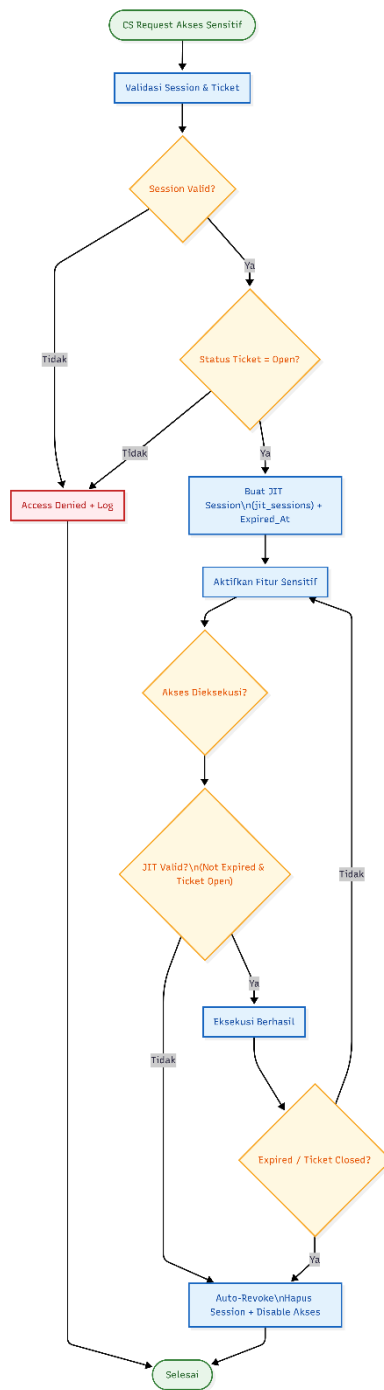
Adapun alur kerja *JIT Access* yang dirancang adalah sebagai berikut:

1. Inisiasi (Request), Customer Service (CS) mengajukan permintaan eskalasi wewenang melalui antarmuka sistem, dalam konteks tiket yang sedang ditangani.
2. Validasi Sistem (Auto-Approval Logic), Middleware JIT secara otomatis melakukan verifikasi terhadap validitas sesi

CS serta memastikan bahwa tiket masih berada dalam status aktif ("Open"). Pada tahap ini, proses persetujuan tidak melibatkan administrator, sehingga tetap efisien namun tetap terkontrol.

3. Eskalasi Sementara (Grant) Apabila validasi berhasil, sistem akan membuat sesi JIT baru pada basis data (*jit_sessions*) yang mencakup informasi seperti ID CS, ID Tiket, jenis fitur sensitif yang diakses, serta batas waktu kedaluwarsa (*Expired_At*). Setelah sesi ini terbentuk, fitur sensitif akan diaktifkan sementara.
4. Pencabutan Akses (Auto-Revoke), Setiap permintaan eksekusi fitur sensitif akan selalu divalidasi terhadap stempel waktu (*timestamp*). Jika waktu saat ini telah melewati batas *Expired_At* (misalnya 15 menit) atau status tiket telah berubah menjadi "Closed", maka sistem akan secara otomatis mencabut akses dengan menghapus sesi JIT dan menonaktifkan kembali fitur sensitif.

Sebagai hasil dari perancangan ini, mekanisme *JIT Access* memastikan bahwa hak akses terhadap fungsi kritikal hanya diberikan dalam durasi terbatas dan dalam konteks yang terverifikasi. Dengan demikian, risiko penyalahgunaan akses dapat diminimalkan. Gambaran Perancangan *Just-In-Time Access* dapat dilihat pada gambar 3.4.



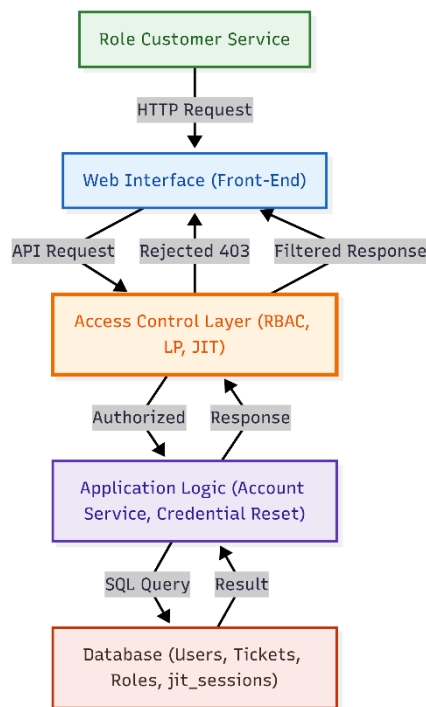
Gambar 3. 4 Perancangan Mekanisme *Just-In-Time Access*

3.5 Arsitektur Tingkat Tinggi (*High-Level Architecture*)

Arsitektur sistem pada penelitian ini dirancang untuk merepresentasikan alur kerja operasional *back-end* dompet digital. Fokus utama arsitektur ini

terletak pada pemisahan antara logika operasional aplikasi dengan *Access Control Layer* (lapisan kontrol akses), sehingga pengujian keamanan otorisasi dapat dilakukan secara terisolasi dan terukur.

Secara umum, arsitektur tingkat tinggi (*high-level architecture*) dari prototipe ini divisualisasikan pada Gambar 3.5.



Gambar 3. 5 Arsitektur Tingkat Tinggi (High-Level Architecture)

Berdasarkan alur arsitektur tersebut, komponen-komponen utama dalam sistem beroperasi dengan rincian sebagai berikut:

1. **Antarmuka Pengguna (*Front-end*)**: Merupakan media interaksi berbasis web yang digunakan oleh Customer Service (CS) untuk mengakses sistem. Melalui antarmuka ini, pengguna dapat melihat daftar tiket, mengakses data nasabah secara terbatas, serta mengajukan permintaan akses fitur sensitif melalui mekanisme *Just-In-Time (JIT)*. Setiap interaksi pengguna dikirim dalam bentuk *HTTP request* menuju sistem backend.
2. **Lapisan Kontrol Akses (*Access Control Layer / Middleware*)**: Lapisan ini berperan sebagai *security gate* utama dalam arsitektur

sistem. Seluruh *API request* dari front-end akan diverifikasi terlebih dahulu sebelum diteruskan ke logika aplikasi. Mekanisme yang diterapkan meliputi:

- *RBAC (Role-Based Access Control)*: Memvalidasi peran pengguna
- *Least Privilege (LP)*: Membatasi akses berdasarkan konteks tiket
- *Just-In-Time (JIT)*: Mengatur akses sementara berbasis waktu

Jika permintaan tidak memenuhi kriteria, sistem akan langsung mengembalikan respons *HTTP 403 (Forbidden)* tanpa meneruskan ke lapisan berikutnya.

3. *Logika Aplikasi (Application Logic)*: Lapisan ini menangani proses bisnis utama sistem, seperti eksekusi pembukaan blokir akun dan reset kredensial. Logika aplikasi hanya akan dijalankan apabila permintaan telah lolos validasi dari *Access Control Layer (authorized request)*. Dengan demikian, lapisan ini tidak perlu menangani validasi keamanan secara langsung.
4. *Basis Data (Database)*: Merupakan penyimpanan data relasional yang digunakan oleh sistem. Database menyimpan berbagai entitas seperti data pengguna, tiket komplain, peran (roles), serta tabel khusus *jit_sessions* yang digunakan untuk mencatat sesi akses sementara. Interaksi dengan database dilakukan melalui *query* dari lapisan *Application Logic*, dan hasilnya dikembalikan secara berjenjang melalui *middleware* hingga ke pengguna.

Dengan struktur arsitektur ini, mekanisme pembatasan lingkup data maupun durasi hak akses sepenuhnya dikendalikan secara terpusat di dalam *Access Control Layer*, sehingga mencegah interaksi langsung yang tidak sah antara pengguna internal dengan *database* sensitif nasabah.

3.6 Lingkungan Implementasi

Tahapan perancangan dan pengujian prototipe sistem dompet digital ini membutuhkan spesifikasi lingkungan pengembangan (*development environment*) yang memadai. Lingkungan implementasi dibagi menjadi dua kategori utama, yaitu perangkat keras (*hardware*) dan perangkat lunak (*software*), dengan rincian sebagai berikut:

3.6.1 Kebutuhan Perangkat Keras (*Hardware*)

Perangkat keras yang digunakan dalam penelitian ini berfungsi untuk mendukung proses pengembangan sistem (*coding*), kompilasi, serta simulasi pengujian secara lokal (*localhost environment*). Spesifikasi perangkat yang digunakan dapat dilihat pada tabel 3.5 berikut:

Tabel 3. 5 Kebutuhan Perangkat Keras (*Hardware*)

No	Komponen	Spesifikasi
1.	Prosesor	AMD Ryzen 7 5700
2.	Memori (RAM)	24 GB
3.	Penyimpanan	SSD (Minimal 512 GB)
4.	Perangkat Tambahan	Laptop/PC dengan koneksi internet

Perangkat dengan spesifikasi tersebut dinilai memadai untuk menjalankan lingkungan pengembangan seperti *web server*, *database server*, serta *tools development* secara bersamaan tanpa mengalami kendala performa yang signifikan.

3.6.2 Kebutuhan Perangkat Lunak (*Software*) dan Teknologi

Sistem prototipe ini dikembangkan menggunakan tumpukan teknologi (*tech stack*) modern yang relevan dengan standar industri, guna memastikan *Access Control Layer* dapat memproses logika keamanan secara cepat dan efisien. Teknologi yang digunakan meliputi:

1. Bahasa Pemrograman dan *Framework Back-end*: Menggunakan bahasa pemrograman Golang (Go) dengan *framework* Gin HTTP. Gin dipilih karena memiliki performa pemrosesan *routing* yang sangat cepat dan ideal untuk membangun *middleware* kustom guna mencegah (*intercept*) *request* dalam penerapan *Least Privilege* dan validasi *token Just-In-Time (JIT)*.
2. Antarmuka Pengguna (*Front-end*): Menggunakan Next.js (berbasis React). *Framework* ini digunakan untuk membangun *dashboard* interaktif bagi *Customer Service (CS)* dengan performa pemuatan halaman yang optimal.
3. Sistem Manajemen Basis Data: Menggunakan MySQL untuk mengelola data relasional yang mencakup tabel profil nasabah, manajemen tiket layanan, dan tabel log sesi JIT
4. Komunikasi *Real-Time (WebSocket)*: Menggunakan library Gorilla WebSocket pada sisi Golang. Teknologi ini diimplementasikan untuk menyediakan fitur *live chat* pada sistem tiket komplain, sekaligus difungsikan untuk sinkronisasi waktu (*real-time update*) antara *back-end* dan *front-end*. Melalui WebSocket, status pencabutan akses JIT (*Auto-Revoke*) dan *countdown timer* dapat langsung mengunci layar CS tanpa memerlukan pemuatan ulang (*refresh*) halaman.
5. Alat Pendukung Pengembangan (*Tools*):
 - Visual Studio Code (VS Code): Berfungsi sebagai *Integrated Development Environment (IDE)* utama untuk penulisan kode.
 - Postman: Alat bantu untuk melakukan pengujian (*testing*) terhadap *endpoint* API, memverifikasi respons *middleware* saat akses ditolak (*Access Denied*), dan menyimulasikan *request* eskalasi JIT sebelum diintegrasikan dengan *front-end*.
 - Git: Digunakan sebagai sistem pengontrol versi (*version Control system*) untuk manajemen kode sumber.

3.7 Skenario Pengujian dan Metode Evaluasi

Evaluasi pada penelitian ini dilakukan menggunakan metode *Scenario-Based Testing* dengan pendekatan *Black-Box Testing*. Pengujian difokuskan pada pengujian fungsionalitas di *Access Control Layer* (lapisan otorisasi) untuk memvalidasi apakah prinsip *Least Privilege* (LP) dan *Just-In-Time* (JIT) *Access* telah berjalan sesuai dengan rancangan sistem, tanpa menghambat operasional sistem.

Pengujian skenario dibagi menjadi tiga aspek utama yang merepresentasikan tujuan penelitian, yaitu: (1) Evaluasi *Least Privilege*, (2) Evaluasi *Just-In-Time Access*, dan (3) Evaluasi Konsistensi Operasional.

3.7.1 Skenario Pengujian *Least Privilege* (Pembatasan Lingkup)

Pengujian ini bertujuan untuk memverifikasi bahwa *Customer Service* (CS) tidak memiliki *standing privileges* untuk mengeksplorasi data nasabah secara bebas, melainkan dibatasi secara ketat berdasarkan konteks penugasan tiket. Skenario Pengujian *Least Privilege* dapat dilihat pada Tabel 3.6.

Tabel 3. 6 Skenario Pengujian *Least Privilege*

ID	Skenario Uji	Tindakan / Trigger	Ekspektasi Hasil (Expected Result)
LP-01	Akses Data dengan Tiket Valid	CS membuka detail nasabah dari Nomor Tiket yang ditugaskan kepadanya.	Berhasil. Middleware mengizinkan akses baca data KYC dan mutasi nasabah tersebut.
LP-02	Akses Data di Luar Konteks (Akses Ilegal)	CS mencoba memanipulasi URL atau API untuk membuka data nasabah yang tidak memiliki tiket aktif atau bukan tugasnya.	Ditolak (<i>Access Denied</i>). Sistem memblokir request karena tidak memenuhi prinsip <i>Need-to-Know</i> .

Berdasarkan tabel tersebut, mekanisme *Least Privilege* diharapkan harus berhasil membatasi akses data sesuai konteks penugasan, sehingga mencegah eksplorasi data di luar kebutuhan operasional.

3.7.2 Skenario Pengujian *Just-In-Time Access* (Pembatasan Durasi)

Pengujian ini bertujuan untuk memastikan bahwa fitur eksekusi sensitif (seperti Modifikasi Status Akun/Buka Blokir) tidak aktif secara *default*, dan dapat diaktifkan sementara waktu melalui mekanisme *Auto-Approval* sistem, lalu dicabut secara otomatis.

Tabel 3. 7 Skenario Pengujian *Just-In-Time Access*

ID	Skenario Uji	Tindakan / Trigger	Ekspektasi Hasil (Expected Result)
JIT-01	Kondisi Default Eksekusi	CS membuka halaman tiket valid, kemudian langsung menekan tombol eksekusi sensitif tanpa melakukan request JIT.	Ditolak. Tombol eksekusi dalam keadaan terkunci (disabled) dan API menolak request.
JIT-02	Permintaan (Request) JIT Valid	CS menekan tombol "Request JIT" dan sistem memvalidasi bahwa tiket masih berstatus Open.	Disetujui otomatis. Sesi JIT terbentuk, tombol eksekusi aktif, dan timer (± 15 menit) mulai berjalan.
JIT-03	Eksekusi Saat Sesi JIT Aktif	CS melakukan aksi sensitif (misalnya buka blokir akun) saat sesi JIT masih aktif.	Berhasil. Sistem mengeksekusi perintah sesuai permintaan.

JIT-04	Pencabutan Otomatis (Auto-Revoke)	CS mencoba melakukan eksekusi setelah waktu JIT habis atau setelah tiket ditutup (Resolved/Closed).	Ditolak. Sistem mencabut akses (revoked), menonaktifkan tombol eksekusi, dan menolak request API.
--------	-----------------------------------	---	---

Berdasarkan tabel tersebut , mekanisme JIT *Access* diharapkan harus mampu mengontrol durasi akses secara dinamis dan memastikan hak akses sensitif hanya aktif dalam periode yang terbatas.

3.7.3 Skenario Pengujian Simulasi Penyalahgunaan

Pengujian ini dilakukan untuk memverifikasi bahwa mekanisme kontrol akses berbasis *Least Privilege* (LP) dan *Just-In-Time* (JIT) *Access* mampu membatasi penyalahgunaan hak akses oleh pengguna internal dengan beberapa skenario uji. Skenario yang diuji merepresentasikan kondisi di mana pengguna mencoba mengakses data atau fitur di luar konteks tugas yang sah.

Tabel 3. 8 Skenario Pengujian Simulasi Penyalahgunaan

ID	Skenario Uji	Tindakan / Trigger	Ekspektasi Hasil (Expected Result)
SP-01	CS akses tiket yang bukan miliknya	CS mencoba membuka detail tiket yang tidak ditugaskan kepadanya	Ditolak. Sistem menampilkan pesan <i>Access denied</i> karena tidak sesuai assignment
SP-02	CS akses data tanpa tiket	CS mencoba mengakses data nasabah tanpa melalui tiket yang valid	Ditolak. Sistem menolak permintaan karena tidak memenuhi konteks <i>Least Privilege</i>

SP-03	CS eksekusi fitur sensitif tanpa JIT	CS mencoba melakukan aksi seperti reset password tanpa aktivasi JIT	Ditolak. Sistem tidak mengizinkan eksekusi fitur sensitif
SP-04	CS menggunakan akses setelah JIT expired	CS mencoba mengeksekusi fitur sensitif setelah durasi JIT berakhir	Ditolak. Sistem mencabut akses secara otomatis (<i>auto-revoke</i>)
SP-05	CS akses data sensitif tanpa konteks lengkap	CS mencoba melihat data KYC, saldo, atau riwayat transaksi tanpa tiket aktif	Ditolak. Akses data sensitif hanya diizinkan dalam konteks tiket yang valid
SP-06	CS modifikasi akun tanpa validasi konteks	CS mencoba mengubah email, membuka blokir akun, atau reset PIN tanpa tiket + JIT	Ditolak. Sistem memerlukan validasi konteks dan sesi JIT aktif

Berdasarkan tabel tersebut, sistem berhasil menolak seluruh percobaan akses yang tidak sesuai dengan konteks operasional. Hal ini menunjukkan bahwa penerapan mekanisme *Least Privilege* dan *Just-In-Time Access* efektif dalam mencegah penyalahgunaan hak akses oleh pengguna internal.

3.7.4 Teknik Analisis dan Evaluasi Hasil

Evaluasi pada penelitian ini menggunakan pendekatan analisis deskriptif kualitatif yang didasarkan pada hasil pengujian skenario fungsional (*Scenario-Based Testing*). Mengingat penelitian ini berfokus pada perancangan dan implementasi satu prototipe *Access Control Layer*, evaluasi dilakukan melalui

validasi perilaku sistem terhadap skenario yang telah dirancang dengan ekspektasi hasil yang telah ditetapkan pada Tabel 3.6 hingga Tabel 3.8.

Analisis dan penarikan kesimpulan evaluasi dititikberatkan pada dua indikator keberhasilan utama, yaitu:

1. **Pembatasan Lingkup Akses (Aspek *Least Privilege*):** Dievaluasi berdasarkan keberhasilan sistem (*middleware*) dalam memblokir dan menolak upaya pengguna internal yang mencoba melakukan eksplorasi data sensitif di luar konteks ID Tiket yang ditugaskan kepadanya.
2. **Peniadaan Hak Akses Permanen (Aspek *JIT Access*):** Dievaluasi berdasarkan ketepatan sistem dalam memvalidasi pemberian hak eksekusi sementara, serta keberhasilan sistem dalam mencabut hak tersebut secara otomatis (*Auto-Revoke*) saat batas waktu kedaluwarsa habis atau tiket ditutup, sehingga menutup celah potensi penyalahgunaan akses.

Hasil dari pengujian indikator-indikator tersebut kemudian akan diuraikan untuk menarik kesimpulan penelitian. Analisis ini ditujukan untuk mengevaluasi apakah integrasi prinsip *Least Privilege* dan *Just-In-Time Access* pada layer kontrol aplikasi mampu secara efektif membatasi ruang lingkup dan durasi hak akses. Dengan pendekatan ini, evaluasi tidak hanya menilai keberhasilan fungsi sistem, tetapi juga efektivitas mekanisme kontrol akses dalam menghadapi kondisi normal maupun potensi penyalahgunaan.

DAFTAR PUSTAKA

- Ajay Benadict Antony Raju. (2021). Zero Trust Architecture for Financial Institutions. *International Journal For Multidisciplinary Research*, 3(5). <https://doi.org/10.36948/ijfmr.2021.v03i05.27000>
- Atlam, H. F., & Yang, Y. (2025). Enhancing Healthcare Security: A Unified RBAC and ABAC Risk-Aware Access Control Approach. *Future Internet*, 17(6), 262. <https://doi.org/10.3390/fi17060262>
- Bates, C., Joseph, C., Tate, Z., Walsh, M., Leonard, P., & Oluwabukunmi Okunola, C. (2025). *Advanced Security Controls for Protecting Sensitive Data in Database as a Service Systems Literature review 1. Introduction & scope*.
- Behringer, F., & Baumann, P. (2025). Integrating identity and Access management and privileged Access management for enhanced identity security in financial institutions: A zero-trust approach. *Cyber Security: A Peer-Reviewed Journal*, 9(2), 114. <https://doi.org/10.69554/YRMM1823>
- Deliu, D., & Moldovan, A. (2025). *Fintech 5.0: From Shadows to Clarity—The Future of Transparency in Financial Organizations* (pp. 285–347). https://doi.org/10.1007/978-3-032-03523-3_12
- Ebad, S. A., & Amara, M. (2026). The Principle of *Least Privilege* in Microservices: A Systematic Mapping Study. *Applied Sciences*, 16(3), 1495. <https://doi.org/10.3390/app16031495>
- Farhadighalati, N., Estrada-Jimenez, L. A., Nikghadam-Hojjati, S., & Barata, J. (2025). A Systematic Review of Access Control Models: Background, Existing Research, and Challenges. *IEEE Access*, 13, 17777–17806. <https://doi.org/10.1109/ACCESS.2025.3533145>
- Gupta, A., Dwivedi, D. N., & Shah, J. (2023). *Overview of Technology Solutions* (pp. 25–39). https://doi.org/10.1007/978-981-99-2571-1_3
- Habeeb Omotunde, & Maryam Ahmed. (2023). A Comprehensive Review of Security Measures in Database Systems: Assessing Authentication, Access Control, and Beyond. *Mesopotamian Journal of CyberSecurity*, 2023, 115–133. <https://doi.org/10.58496/MJCSC/2023/016>

- Haber, M. J., & Rolls, D. (2020). *Just-In-Time Access Management*. In *Identity Attack Vectors* (pp. 151–155). Apress. https://doi.org/10.1007/978-1-4842-5165-2_14
- Kraiwanit, T., Limna, P., & Wattanasin, P. (2024). Digital wallet dynamics: Perspectives on potential Worldcoin adoption factors in a developing country's FinTech Sector. *Journal of Open Innovation: Technology, Market, and Complexity*, 10(2), 100287. <https://doi.org/10.1016/j.joitmc.2024.100287>
- Kumar, P. (2025). Next-generation secure authentication and Access Control architectures: advanced techniques for securing distributed systems in modern enterprises. *International Journal of Computational and Experimental Science and Engineering*, 11(3). <https://doi.org/10.22399/ijcesen.3294>
- Mohamed, I. A., Abdulla, H., Mohabilasha, M. M., Ahmed, F., Chandre, P., & Mahalle, P. (2026). *reKYC for Fintech Security: A Privacy-Preserving Approach to Digital Wallet Verification* (pp. 420–434). https://doi.org/10.1007/978-3-032-13203-1_40
- Nagaraju Velur. (2025). The Evolution of Enterprise Security Systems in Cloud-native Architectures: From Perimeter-Based to Automated, Granular Models. *Journal of Information Systems Engineering and Management*, 10(63s), 1457–1464. <https://doi.org/10.52783/jisem.v10i63s.14113>
- Olaide, A., Kalilu, J., & Ajani, B. (2025). *Least Privilege Access in Practice: Minimising Insider Risk While Maintaining Operational Efficiency*.
- Olorunlana, T. J. (2025). *Least Privilege and Access Control Principles in Enterprise Network Security: A Comparative Analysis of the United States and Global Practices*. *International Journal of Science Architecture Technology and Environment*, 1. <https://doi.org/10.63680/ijstate1225001.001>
- Park, J.-H., Park, S.-C., & Youm, H.-Y. (2025). A Proposal for a Zero-Trust-Based Multi-Level Security Model and Its Security Controls. *Applied Sciences*, 15(2), 785. <https://doi.org/10.3390/app15020785>
- PentaSecurity. (2025). *FinWise Data Breach: Encryption Becomes Your Last Line of Defense*. <https://www.pentasecurity.com/press-releases/finwise-data-breach-encryption/>

- Plachkinova, M., & Knapp, K. (2023). *Least Privilege* across People, Process, and Technology: Endpoint Security Framework. *Journal of Computer Information Systems*, 63(5), 1153–1165.
<https://doi.org/10.1080/08874417.2022.2128937>
- Ragothaman, K., Wang, Y., Rimal, B., & Lawrence, M. (2023). *Access Control* for IoT: A Survey of Existing Research, Dynamic Policies and Future Directions. *Sensors*, 23(4), 1805. <https://doi.org/10.3390/s23041805>
- Rao, S. A. G. (2025). Strategic Value of *Just-In-Time Access Control*: Enhancing Security While Driving Workforce Efficiency in Large-Scale Organizations. *Hampton Global Business Review*.
<https://doi.org/10.70924/uv4px7jt/qhs81bg2>
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture*. <https://doi.org/10.6028/NIST.SP.800-207>
- Subramanyam, S. P. (2025). Zero Trust in Practice: Enhancing Privileged Access Security with *Just-In-Time* (JIT) and Self-Service Models. *International Research Journal of Innovations in Engineering and Technology*, 09(12), 13–18. <https://doi.org/10.47001/IRJIET/2025.912003>
- The Straitstimes. (2022). *Former DBS officer jailed for illegally accessing and leaking customer details | The Straits Times*.
<https://www.straitstimes.com/singapore/courts-crime/former-dbs-officer-jailed-for-illegally-accessing-and-leaking-customer-details>
- Usman, U. I., Ibrahim, M. D., Aliyu, I. A., Isah, U., & Jamal, F. (2025). The Implications of Insider Threats in Financial Institutions: A Review of Challenges and Mitigation Strategies. *International Journal of Innovative Science and Research Technology*, 186.
<https://doi.org/10.38124/ijisrt/25dec240>
- Vikas Prajapati. (2025). Role of Identity and Access Management in Zero Trust Architecture for Cloud Security: Challenges and Solutions. *International Journal of Advanced Research in Science, Communication and Technology*, 6–18. <https://doi.org/10.48175/IJARSCT-23902>
- Waheed, U., Khan, S. A., Masud, M., Jamshed, H., Jumani, T. A., & Malik, N. U. R. (2025). Blockchain-Based, Dynamic Attribute-Based Access Control for Smart Home Energy Systems. *Energies*, 18(8), 1973.
<https://doi.org/10.3390/en18081973>